Steps 1 to 3: Environment, Core Processing and the Main Feature Proof of Concept

Insider Threat Detection System, Capstone Group 7 · 8 November 2026

1. What this document does

It compares the work in the repository with the three student activities of the plan and points to the evidence for each. Details are in the day documents, which are saved in docs/evidence of the repository.

Step	Plan days	What it asks for	Status	Evidence
1. Development environment	22 to 23	Tools, libraries and frameworks; a version-controlled repository; documented environment and dependencies	Done	Day 1 document; docs/TOOLS_AND_ALGORITHMS.md
2. Sample data and core processing	23 to 24	An authorized dataset; the essential processing steps	Done with generated data	Day 2 document; docs/DATA_RULES.md
3. Main advanced feature	24 to 26	A working proof of concept for at least one major feature of the methodology	Done, with the limits in Section 5	Day 3 and Day 5 documents; Figures 1 to 4 below

2. Step 1: development environment

Requirement	What exists	Where
Select tools, libraries and frameworks	Each tool with its version, the reason for the choice and the alternatives	docs/TOOLS_AND_ALGORITHMS.md
Version-controlled repository	A GitHub repository with branches for the work of each stage, merged into main, and a commit history	github.com/NawafAz-ui/insider-threat-detection
Document the environment	Versions of the first laptop and of a second computer (Python 3.14.5, Docker 29.9.2, MongoDB image mongo:7, npm 10.9.2, Vite 5.4.21); a docker-compose file; an example settings file; start and check scripts	docs/TOOLS_AND_ALGORITHMS.md, docker-compose.yml, .env.example, scripts
Document the dependencies	Minimum versions in requirements.txt and package.json; the resolved Python versions in backend/requirements.lock.txt; the run-order dependencies (database before engine, a finished run before results, and so on)	Day 1 document, Section 3

Open points: the requirement files give minimum versions only, so the lock file (from one Windows computer) is the record of what was tested. There is no automatic test run on every push.

3. Step 2: sample data and core processing

Requirement	What exists	Result
Authorized dataset	A generator in the CERT layout (120 users, 90 days, 12 insiders, fixed seed). Adapters for CERT r4.2 and SPEDIA exist but have not been run. Sources, collection steps and input requirements are written down.	108,635 events, 681 malicious events
Import and validation	Chunked reading (500,000 rows); ten validation rules V1 to V10 before any data is read; errors stop the run and warnings are reported	A dataset without device.csv was rejected with the message naming the file
Core processing	Sessions per user and PC, 39 features, per-user baselines, a time-ordered split	7,329 sessions; train 5,130, validation 1,099, test 1,100
Checks	Automated tests	74 passed, 1 skipped (it needs a real MongoDB server)

Open points: real CERT r4.2 and SPEDIA have not been run, and the validator has not been timed on a large release.

4. Step 3: the main advanced feature

The methodology states the contribution as an inspectable combination of session scoring, personal baselines and explanations, not a new detection algorithm. Each part works and has been shown.

Feature	What it does	Proof
Session scoring	Three models, calibration, weights and a flag threshold chosen on validation data give one 0 to 100 risk score. A run can be started and retrained from the dashboard.	Day 3 document, Section 3; Day 5 document, Figures 2 and 3

Feature	What it does	Proof
Personal baselines	Each user has a running mean and spread for 10 behaviors. A session is compared with the user′s own normal.	Day 3 document, Section 2.1; Figure 2 below
Explanations	The three strongest reasons for the XGBoost score and the three largest differences from the user′s normal, in plain words	Figure 1 below; Day 5 document, Figure 5
Evidence-grounded assistant	Answers questions about one session from its stored evidence only	Figures 3 and 4 below
Comparison with simple methods	Three rules and a no-skill line; the models beat all of them	Day 5 document, Section 4

4.1 Screens

Figure 1 shows the page of one flagged session (user U0073). The score is 95 out of 100 and the flag threshold is 8.1. The three model scores are shown (logistic 98, XGBoost 90, Isolation Forest 98). The left box lists what drove the XGBoost score: six visits to file-sharing or leak sites, an activity rate of 9.1 events per hour, and a session length marked minor. The right box lists the differences from this user′s normal: a logon at 22.1h against a usual 10.0h, 5,100 KB of email against 137 KB, and six leak-site visits against none, each ten or more standard deviations above the user′s mean. A notice reminds the analyst that a flag is not proof of wrongdoing. The assistant box says it is read-only and sees only the stored evidence items, with no names and no raw logs.

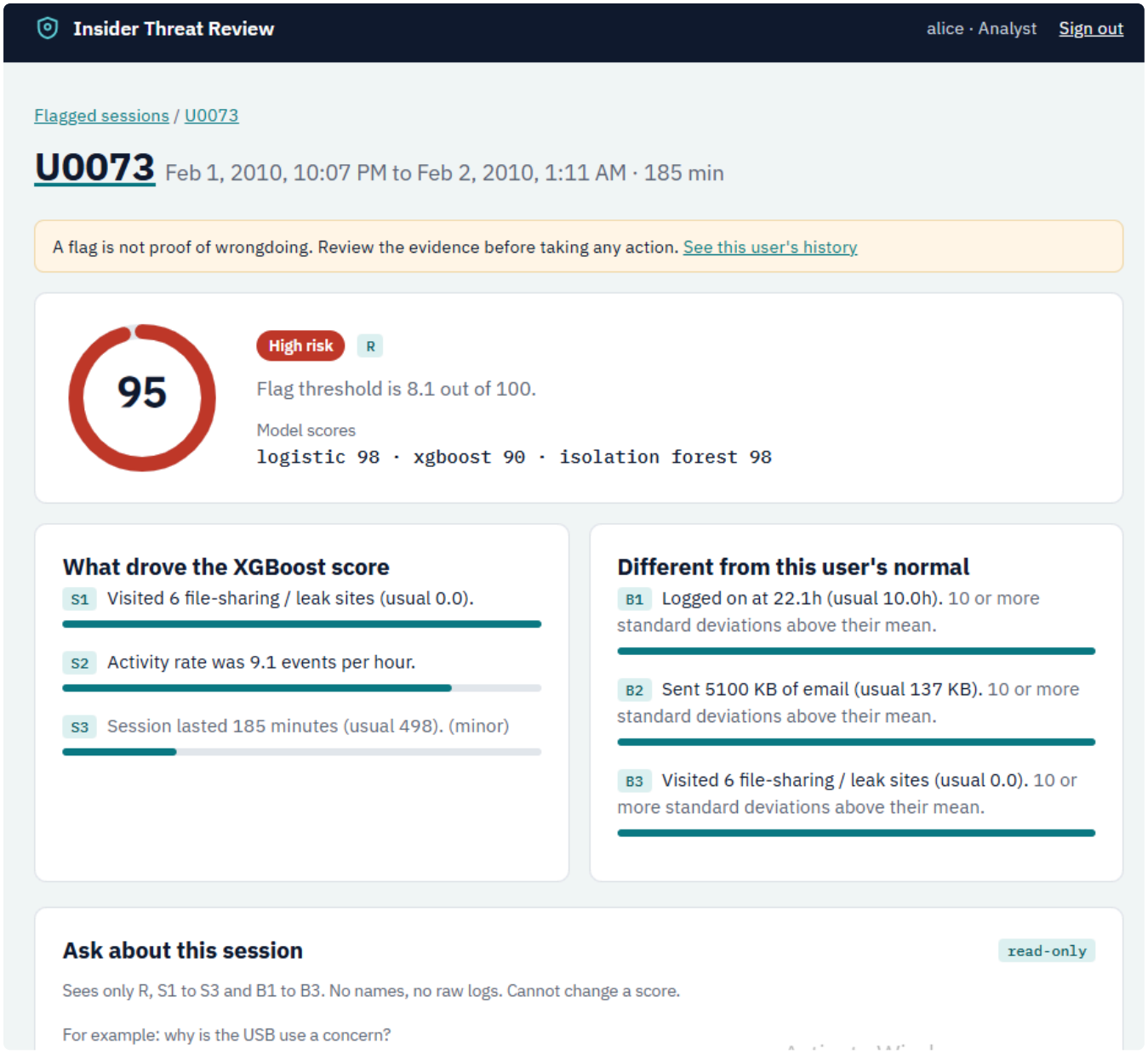


Figure 1. A flagged session with its score, reasons and the assistant box.

Figure 2 shows the history page of the same user: 59 sessions, 5 flagged, highest risk 95. The chart shows one dot per session over time with the flag threshold line, and the table below it shows what is normal for this user (for example a usual logon hour of 10.3 with a spread of 2.3).

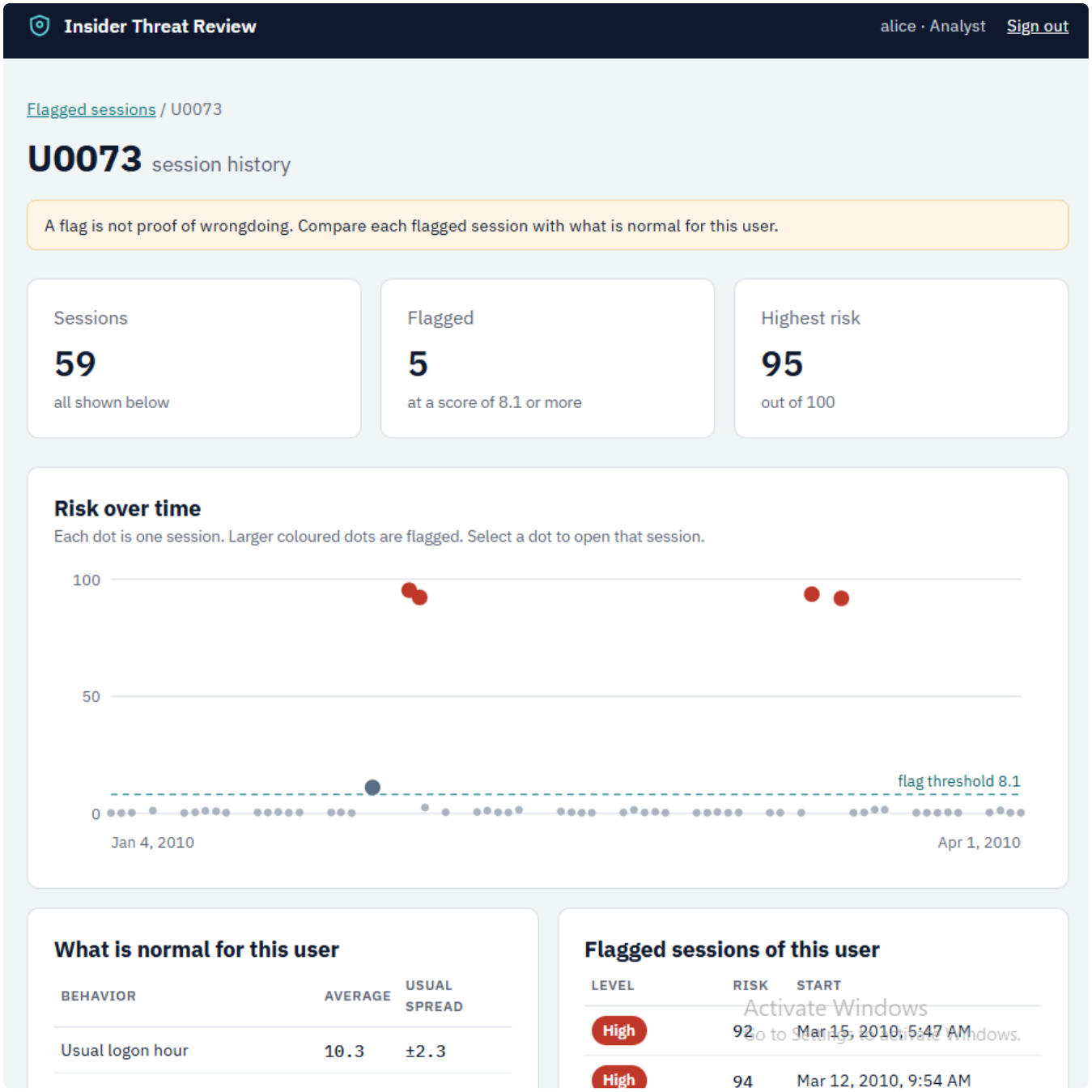


Figure 2. The user history with the risk over time and what is normal for the user.

Figure 3 shows the assistant answering the question Why was this session flagged? The answer names the score, the main reasons and the comparison with the user's normal, cites the evidence items it used (R, B1, S1, S2), and says that it is an offline summary and that no language model was used.

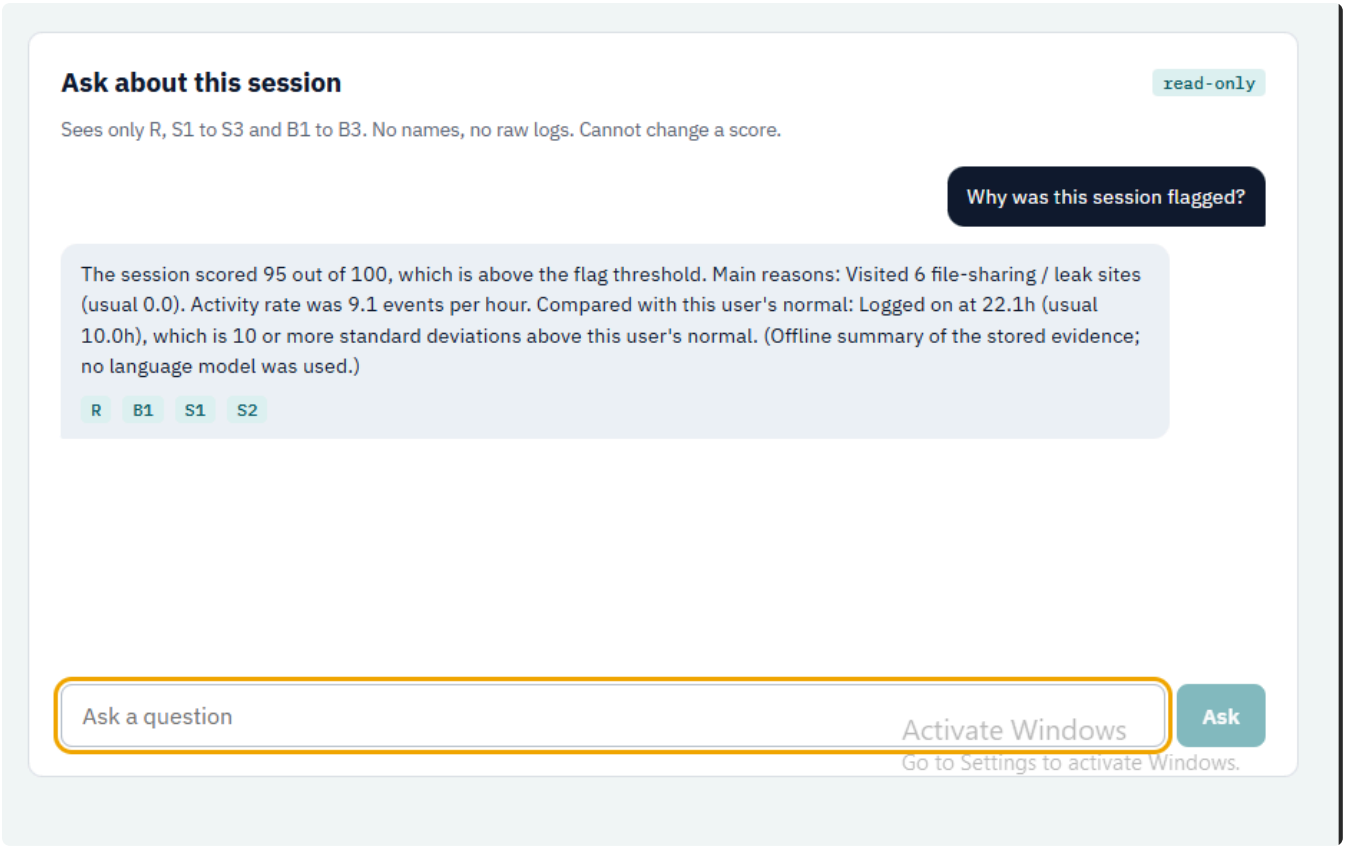


Figure 3. The assistant answers from the stored evidence and cites its items.

Figure 4 shows the question Is this person a thief? The assistant gives the same evidence summary and cites the same items. It makes no accusation and uses nothing beyond the stored evidence.

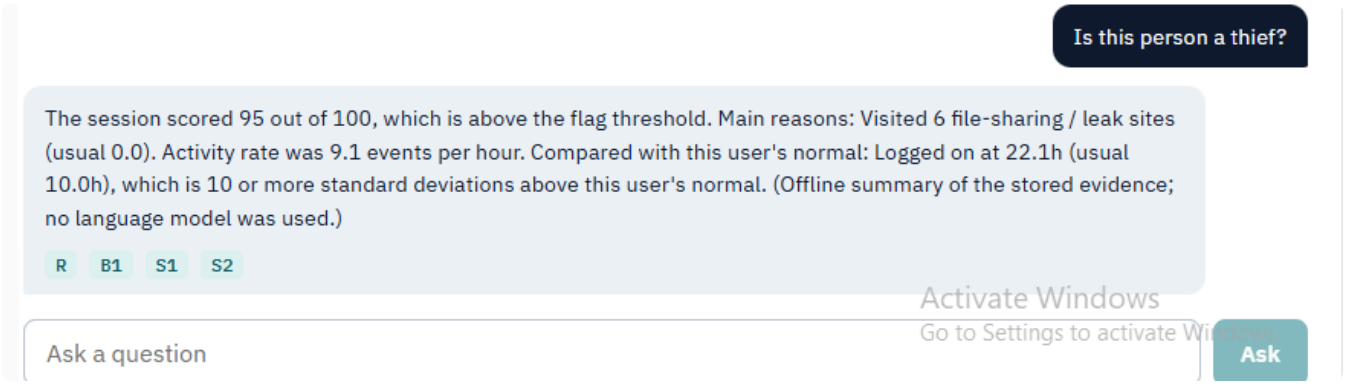


Figure 4. A question about guilt gets the standard evidence summary.

5. Limits

- **The assistant was shown in offline mode only.** Without an API key it builds the answer from a template. The hosted mode instructs the model to explain and not to decide guilt, requires every statement to cite evidence items and checks the numbers, but it has never been run with a real key.

- **The offline assistant does not decline questions it cannot answer.** A question that matches nothing in the evidence, such as the thief question, gets the standard summary instead of the reply that the stored evidence does not support an answer, and the answer does not say that it cannot judge guilt. It is safe because it only repeats stored evidence, but a clearer refusal would be better.
- All data is generated. The results say nothing about real logs.
- Real CERT r4.2 and SPEDIA have not been run.
- The simple reference rules were written by the authors who know the data, so they are not neutral.
- XGBoost results differed between two computers; the cause was not tested (Day 5 document).

6. Where the evidence is

The folder docs/evidence of the repository holds the evidence documents of Days 1, 2, 3 and 5 and this summary, each as a PDF with its screenshots, and a README that lists them.